

INFORME DE AUDITORIA MAQUINA PROFILEPEEK

Plataforma: www.whoami-labs.com

Joseph Chacón

Email: jc05887@gmail.com

INTRODUCCIÓN

El presente informe técnico detalla los resultados y la metodología aplicada durante la prueba de penetración (Pentest) realizada a la aplicación web del laboratorio **ProfilePeek**, alojado en la plataforma de entrenamiento WHOAMI-LABS.

El objetivo principal de esta evaluación fue identificar, explotar y documentar vulnerabilidades de seguridad presentes en la arquitectura de la aplicación, con el fin de evaluar la robustez de sus controles de acceso y la protección de datos confidenciales.

Resumen ejecutivo

Durante la auditoría de seguridad realizada sobre la infraestructura web de la intranet ProfilePeek, se identificaron fallos críticos de control de acceso que comprometen la confidencialidad de la información corporativa.

Mediante técnicas de reconocimiento de puertos, análisis de tráfico HTTP y pruebas de fuzzing automatizado, se logró enumerar el directorio completo de empleados de la organización. El hallazgo más relevante corresponde a una vulnerabilidad de Referencia Directa Insegura a Objetos (IDOR / BOLA), la cual permitió acceder a un perfil administrativo con privilegios elevados (CISO Admin) y extraer la información confidencial del sistema (BURP{idor_header_scope}).

Resumen de Vulnerabilidades Halladas

A continuación, se consolidan los hallazgos de seguridad identificados durante la prueba de penetración, acompañados de su clasificación de severidad bajo el estándar **CVSS v3.1**, identificadores de vulnerabilidad comunes (**CVE/CWE**) y sus respectivas medidas de remediación:

Matriz de Vulnerabilidades y Severidad (CVSS v3.1)

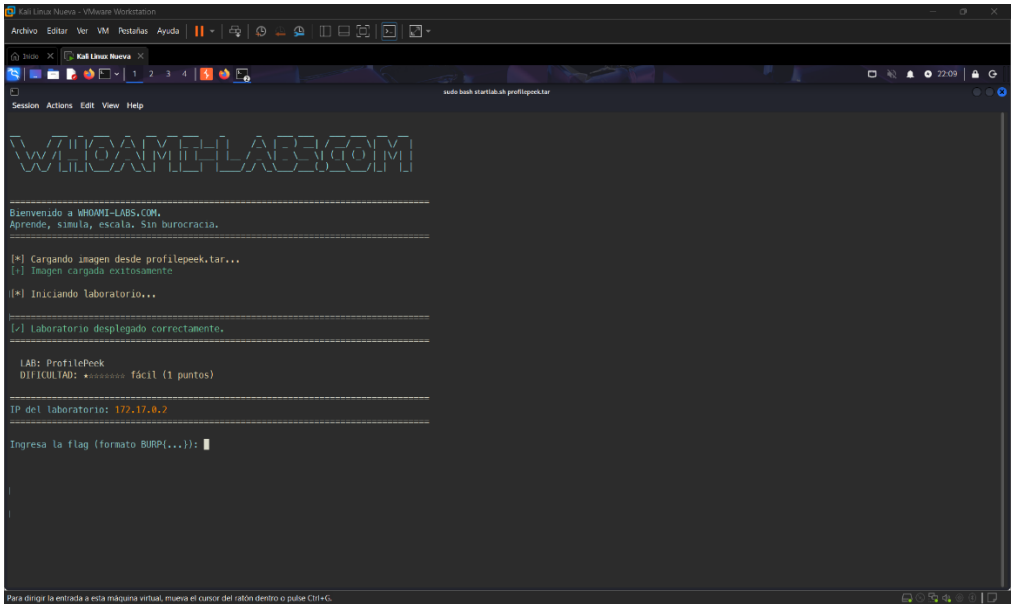
Vulnerabilidad	Severidad / Puntuación	Desglose del Riesgo (Fácil de Entender)	Impacto Real	Remediación Recomendada
Referencia Directa Insegura a Objetos (IDOR / BOLA) ***(CWE-639 / CWE-284)***	**ALTA** **(7.5 / 10)**	• **Origen:** Remoto (Internet / Red) • **Complejidad:** Muy Baja (Fácil) • **Privilegios:** Ninguno (Anónimo) • **Interacción:** No requiere interacción del usuario	Un atacante no autenticado puede consultar o descargar los perfiles y datos confidenciales de **todos los empleados** cambiando un número en la URL.	Validar permisos en el servidor comprobando que el uid solicitado corresponda al usuario autenticado en la sesión (JWT). Cambiar IDs secuenciales por identificadores **UUIDv4**.
Exposición Directa del Directorio de Usuarios	**MEDIA**	• **Origen:** Remoto	La ruta /profiles muestra públicamente la lista completa de	Restringir el acceso a la ruta /profiles para que solo usuarios

(CWE-200)	**(5.3 / 10)**	• **Complejidad:** Muy Baja • **Privilegios:** Ninguno • **Interacción:** No requiere	empleados y sus roles, facilitando la fase de reconocimiento a un atacante.	autenticados con rol autorizado puedan verla, o eliminar el listado global.
Transmisión de Credenciales en Texto Plano *(CWE-319)*	**MEDIA** **(4.3 / 10)**	• **Origen:** Remoto • **Complejidad:** Baja • **Privilegios:** Ninguno • **Interacción:** Requiere que la víctima inicie sesión	Al no usar cifrado SSL/TLS (HTTPS), un atacante en la misma red local puede interceptar las contraseñas enviadas en el formulario de login.	Implementar un certificado de seguridad **HTTPS (SSL/TLS)** en el servidor web y forzar el uso de co

Metodología

Despliegue del Entorno de Laboratorio

- **Paso / Objetivo:** Iniciar el contenedor/entorno del laboratorio vulnerable "ProfilePeek" provisto por la plataforma *WHOAMI-LABS*.
- **Análisis de Resultados:** Se ejecutó el script de despliegue en la máquina de auditoría (Kali Linux). El script importó exitosamente la imagen profilepeek.tar e inició el laboratorio.

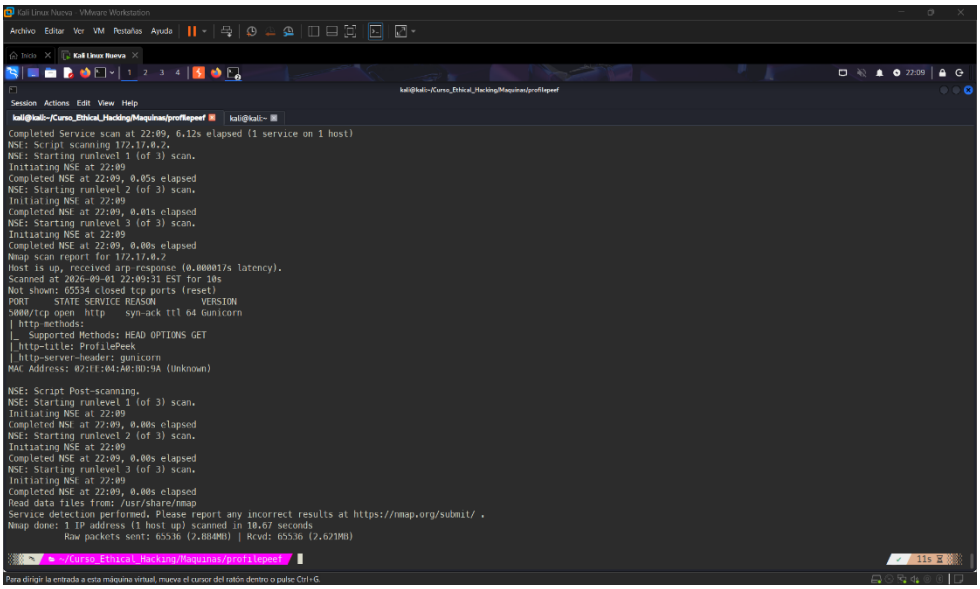


Escaneo de Puertos y Servicios (Reconocimiento de Red)

- **Paso / Objetivo:** Identificar los servicios activos, puertos abiertos y versiones de aplicaciones en ejecución en la IP objetivo (172.17.0.2).

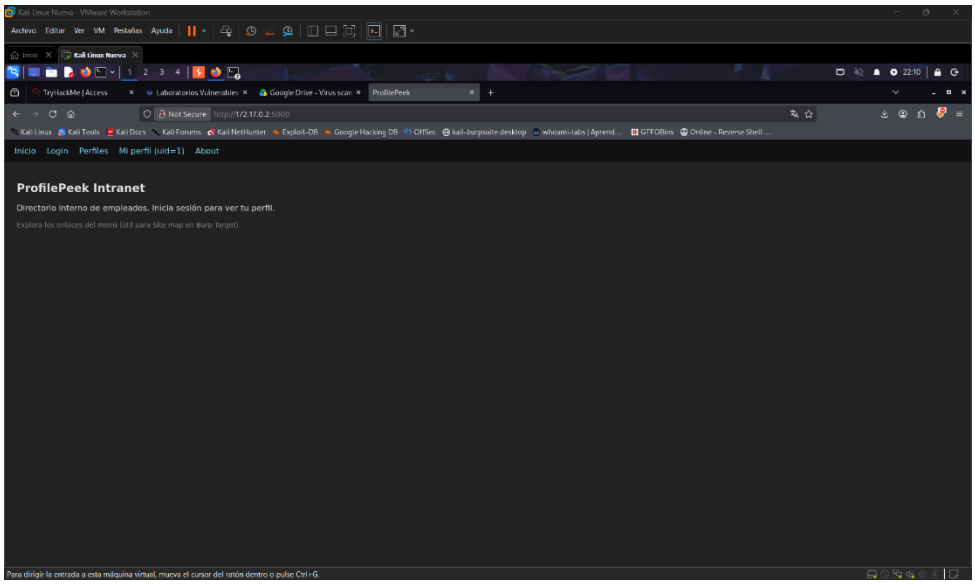
Análisis de Resultados: El escaneo de puertos determinó los siguientes detalles:

- **Puerto 5000/tcp (Abierto):** Ejecuta un servicio HTTP basado en el servidor web **Gunicorn**.
- **Título de la Página Web:** ProfilePeek.



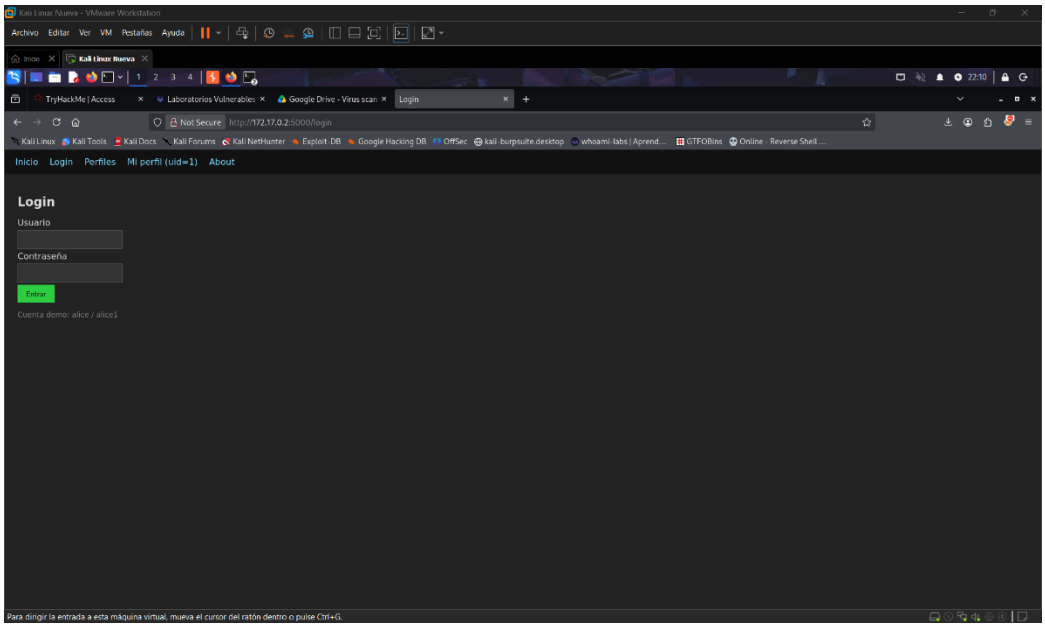
Exploración Inicial de la Aplicación Web (Página Principal)

- **Paso / Objetivo:** Inspeccionar la interfaz web servida en el puerto 5000 a través del navegador web[cite: 2, 3].
- **Navegación / URL:** http://172.17.0.2:5000
- **Análisis de Resultados:** Se accede a la intranet "ProfilePeek Intranet", descrita como un directorio interno de empleados.
    - Presenta un menú superior con las opciones: *Inicio*, *Login*, *Perfiles*, *Mi perfil (uid=1)* y *About*.
    - Una nota en pantalla indica que el sitio es ideal para mapear mediante el mapa de sitio de Burp Suite o exploración manual.



Inspección del Formulario de Autenticación (Login)

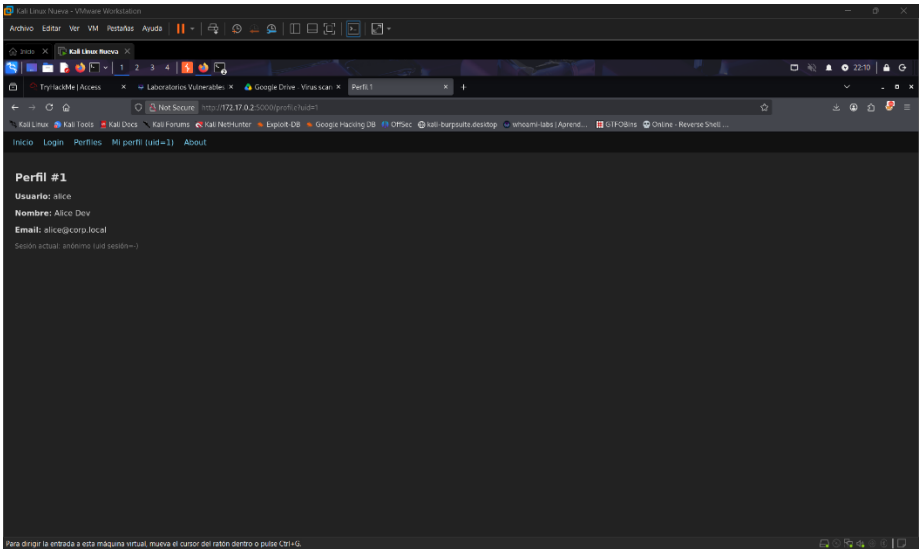
- **Paso / Objetivo:** Evaluar el formulario de inicio de sesión de la aplicación web e identificar posibles credenciales de prueba.
- **Navegación / URL:** http://172.17.0.2:5000/login
- **Análisis de Resultados:** La página de inicio de sesión solicita un *Usuario* y una *Contraseña*. En el pie del formulario se revelan credenciales demo por defecto:
    - **Cuenta demo:** alice / alice1.



Identificación del Vector de Vulnerabilidad (Exploración de Perfiles / IDOR)

- **Paso / Objetivo:** Probar la funcionalidad de visualización de perfiles de usuario y analizar la estructura de las peticiones/parámetros en la URL.
- **Navegación / URL:** http://172.17.0.2:5000/profile?uid=1
- **Análisis de Resultados:** Al consultar el perfil mediante el parámetro uid=1:
    - Se despliega la información perteneciente al usuario alice (Nombre: Alice Dev, Email: alice@corp.local).
    - **Hallazgo Clave:** El estado de la sesión actual muestra Sesión actual: anónimo (uid sesión=-), lo que indica que se está accediendo a la información del perfil **sin necesidad de estar autenticado**. Esto apunta preliminarmente a una

vulnerabilidad de **Referencia Directa Insegura a Objetos (IDOR)** o manipulación de parámetros de consulta (uid



Explotación de la Vulnerabilidad IDOR (Enumeración Secuencial de Perfiles)

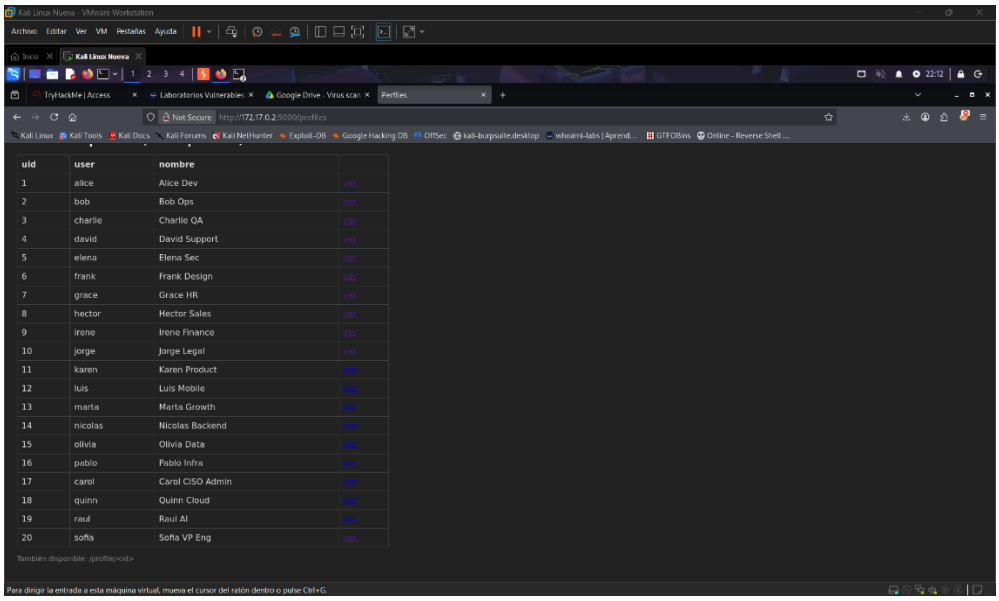
- **Paso / Objetivo:** Validar la vulnerabilidad de Referencia Directa Insegura a Objetos (IDOR) mediante la iteración secuencial del parámetro de consulta uid en la URL para enumerar información confidencial de otros usuarios registrados en el sistema sin autenticación previa.

Análisis de Resultados: Al modificar incrementalmente el identificador de usuario (uid), el control de acceso de la aplicación web falla en verificar los permisos de la sesión actual (Sesión actual: anónimo). Como resultado, se expuso exitosamente la siguiente información de la intranet.

Conclusión Técnica del Hallazgo: La ausencia de controles de autorización (*Broken Object Level Authorization* / BOLA / IDOR) permite a un atacante no autenticado mapear la estructura completa de cuentas de la organización y extraer nombres, roles internos implícitos y direcciones de correo corporativas

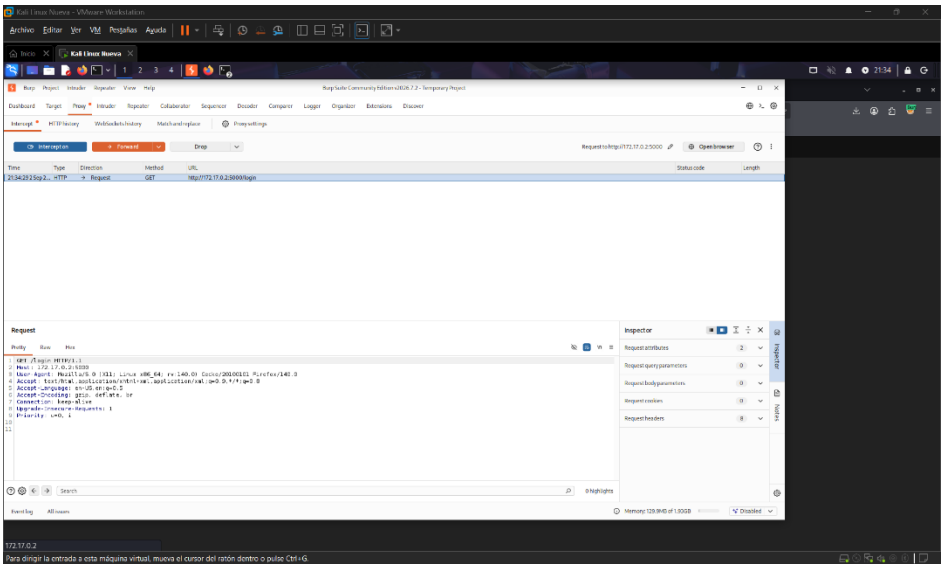
El análisis del parámetro uid confirma que la aplicación no valida la sesión de usuario ni restringe el acceso cruzado a datos personales.

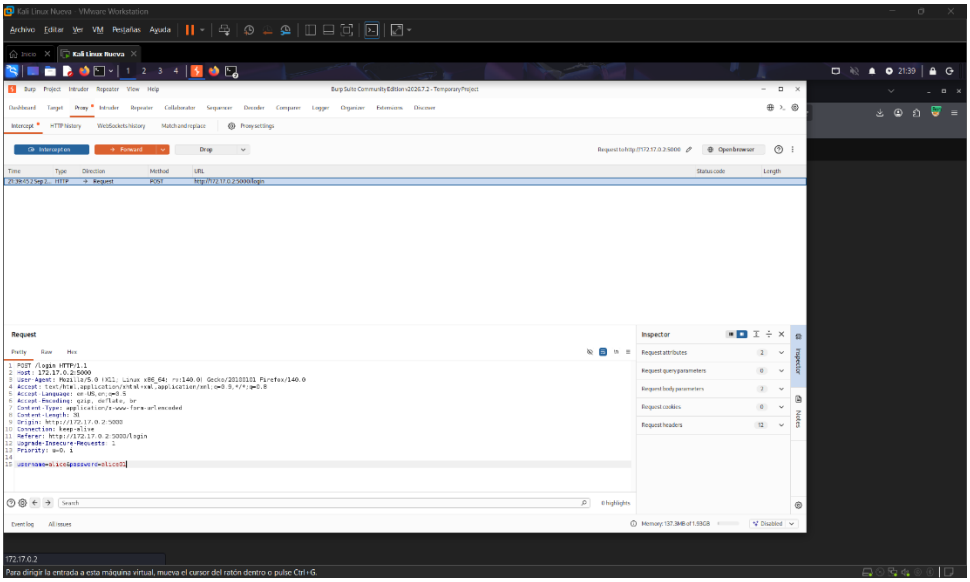
La prueba con uid=20 revela que la numeración de los perfiles continúa más allá de los primeros valores secuenciales, exponiendo perfiles ejecutivos de alto valor dentro de la organización (ej. *VP Eng*). Esto demuestra que un atacante puede automatizar un ataque por fuerza bruta o fuzzing numérico sobre el parámetro uid para cosechar el directorio completo de empleados de la empresa.



Intercepción de Peticiones y Listado Completo de Perfiles

- **Paso / Objetivo:** Mapear la sección /profiles de la aplicación e interceptar las peticiones HTTP de autenticación mediante proxy para analizar el tráfico cliente-servidor.
- **Navegación / Herramientas:** Navegador Web (http://172.17.0.2:5000/profiles) y **Burp Suite Community Edition** (módulo Proxy Intercept).
- **Análisis de Resultados:**
    - **Directorio Completo Expuesto (/profiles):** Se confirma que el punto final /profiles despliega una tabla pública con los 20 usuarios del sistema (uid 1 al 20), sus nombres y roles organizacionales. En el pie de la tabla se destaca la nota: También disponible: /profile/<id>.
    - **Intercepción GET /login:** Se capturó la petición inicial GET /login HTTP/1.1 dirigida al host 172.17.0.2:5000 antes de enviar el formulario de autenticación.

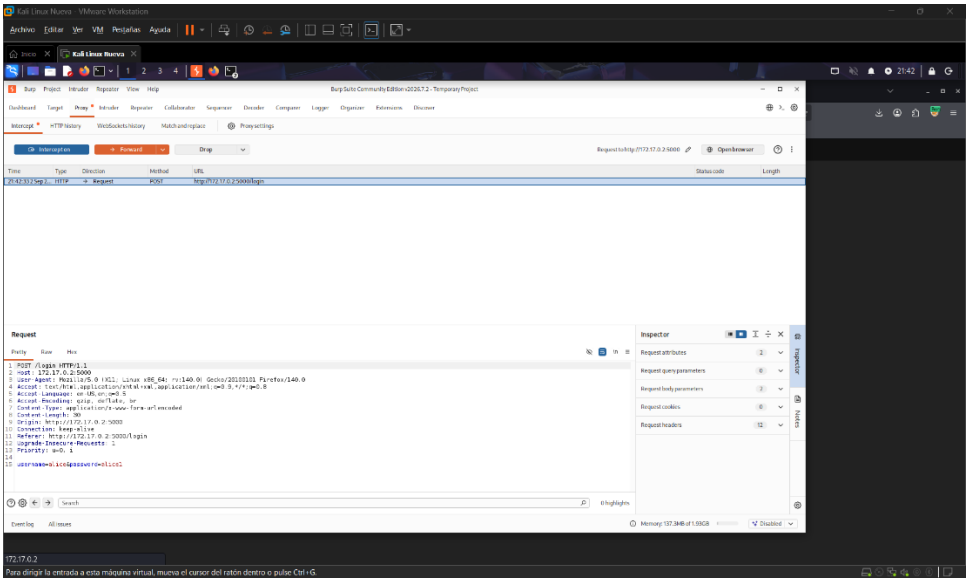




Análisis del Proceso de Autenticación en Burp Suite

- **Paso / Objetivo:** Interceptar y examinar el contenido de la petición POST del formulario de inicio de sesión para evaluar la transmisión de credenciales.
- **Comandos / Herramientas: Burp Suite Proxy** (Intercept).
- **Análisis de Resultados:**
    - **Petición POST Interceptada:** La aplicación envía los datos de autenticación mediante una petición POST /login HTTP/1.1 con la cabecera Content-Type: application/x-www-form-urlencoded.

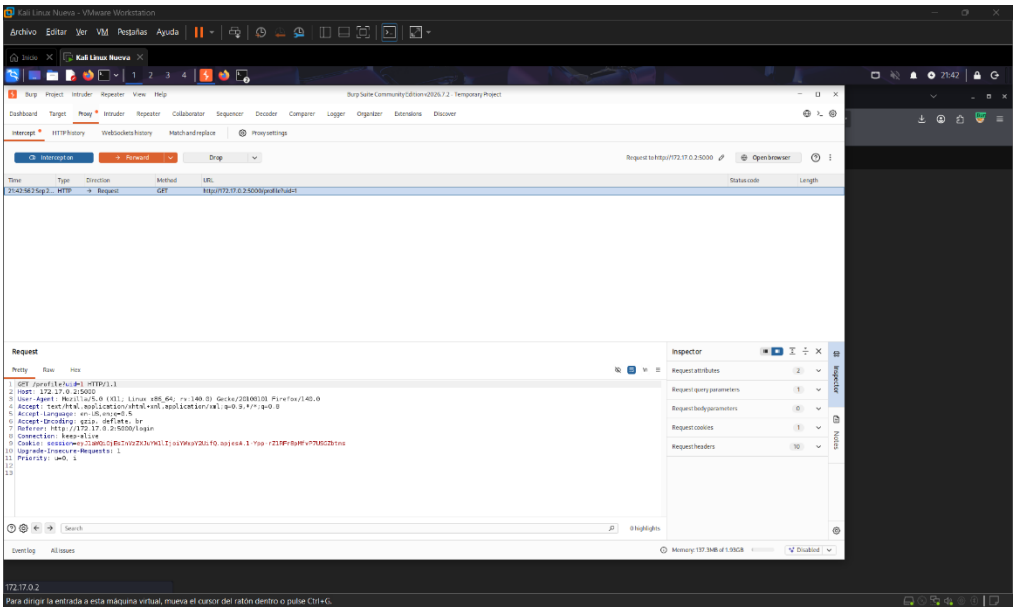
- **Cuerpo de la Petición (Body Parameters):** Se observa el envío explícito de los parámetros username=alice&password=alice01 en texto plano.



Inspección de Sesión y Cookies de Autenticación (JWT Token)

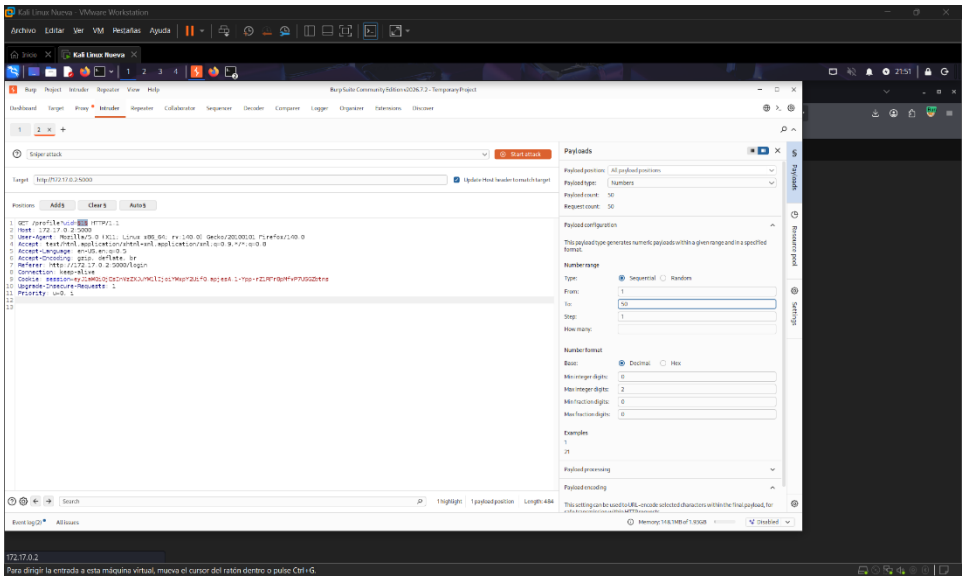
- **Paso / Objetivo:** Analizar la respuesta del servidor y la estructura de las cookies enviadas tras procesar el inicio de sesión para comprender cómo gestiona la aplicación las sesiones de usuario.
- **Comandos / Herramientas: Burp Suite Proxy**.
- **Análisis de Resultados:** Al enviar las credenciales válidas y realizar la redirección hacia GET /profile?uid=1, el navegador adjunta una cabecera Cookie: con un token de sesión de formato estructurado

Hallazgo Clave: El formato de la cookie (eyJhbGci...) corresponde a un **JSON Web Token (JWT)** firmado digitalmente mediante el algoritmo **HS256**. Esto abre la puerta a analizar la firma o el contenido útil del token (*payload*) para evaluar posibles vectores de manipulación de sesión.



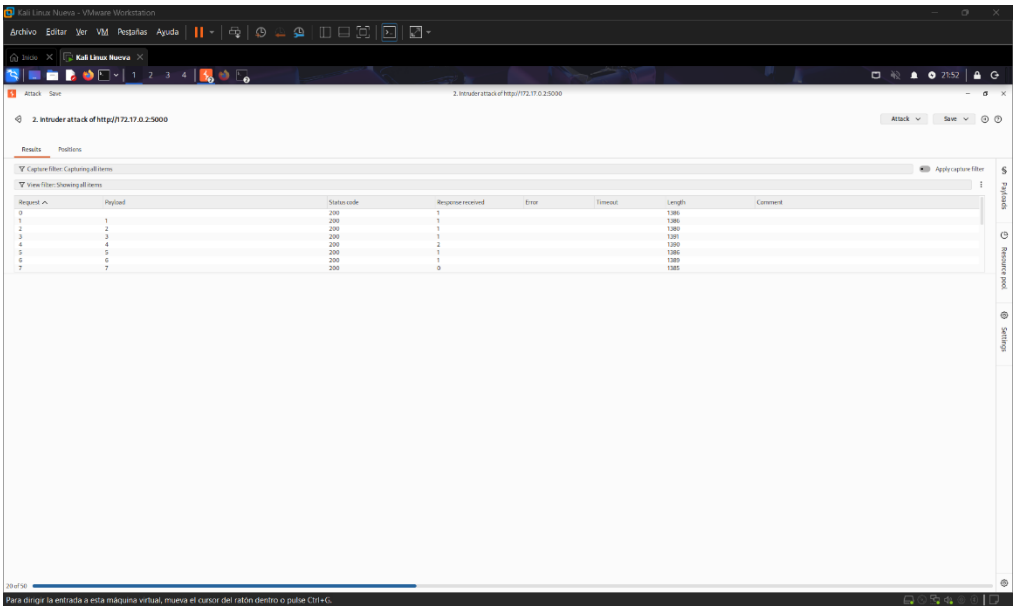
Configuración de Pistas y Payload en Burp Intruder

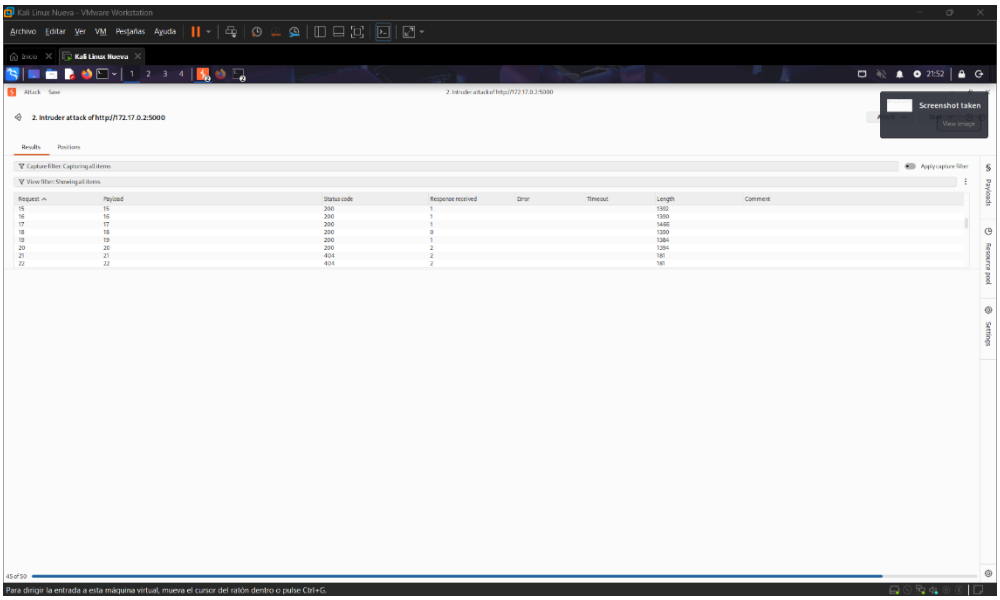
- **Paso / Objetivo:** Automatizar el proceso de pruebas sobre el parámetro uid utilizando el módulo **Burp Intruder** para identificar sistemáticamente todos los perfiles válidos existentes y detectar respuestas anómalas.
- **Comandos / Herramientas: Burp Suite** (Intruder).
- **Configuración del Ataque:**
    - **Tipo de Ataque:** *Sniper*.
    - **Posición del Payload:** Se selecciona el valor del parámetro uid en la petición: GET /profile?uid=§1§ HTTP/1.1.
    - **Tipo de Payload:** *Numbers* (Secuencial).
    - **Rango Definido:** Desde 1 hasta 50, con un paso (step) de 1.



Ejecución y Análisis del Ataque de Fuerza Bruta (Fuzzing)

- **Paso / Objetivo:** Analizar los códigos de estado HTTP y la longitud de las respuestas devueltas para determinar la cantidad exacta de perfiles existentes e identificar desviaciones.
- **Comandos / Herramientas: Burp Suite Intruder** (Results).
- **Análisis de Resultados:**
    - **Identificación del Límite de Perfiles:**
        - Los payloads del **1 al 20** devolvieron un código de estado **200 OK**, confirmando que existen exactamente 20 usuarios en la base de datos/aplicación.
        - A partir del payload **21 en adelante** (hasta el 50), el servidor responde con un código **404 Not Found** y una longitud constante de respuesta de 181 bytes.

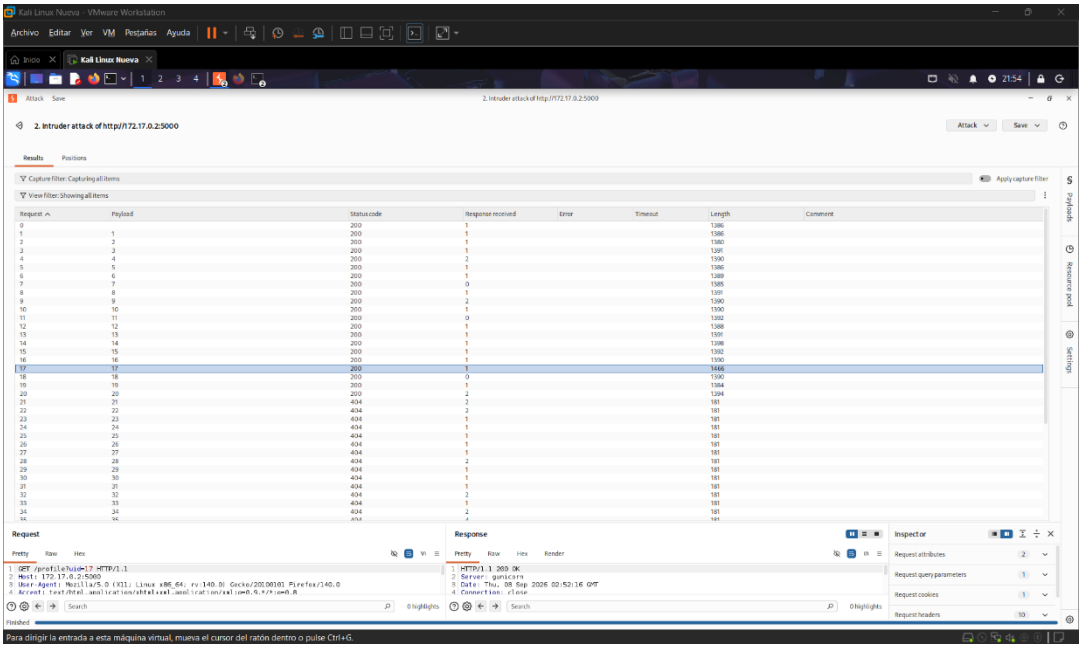




Detección de Anomalía en la Respuesta (Payload uid=17)

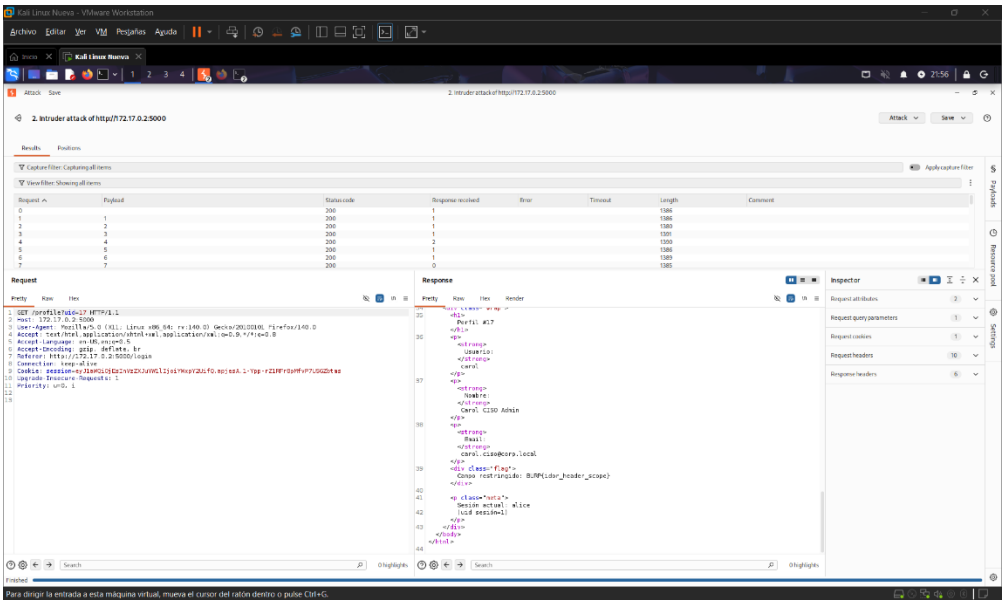
- **Paso / Objetivo:** Inspeccionar en detalle las respuestas HTTP que presentan variaciones significativas en la longitud para detectar información sensible o de privilegios elevados.
- **Comandos / Herramientas: Burp Suite Intruder** (Pestaña Response / Inspección de trama).
- **Análisis de Resultados:**

- **Variación Anómala:** Mientras que la mayoría de las respuestas con código 200 OK rondan entre los 1380 y 1398 bytes, el **payload 17 (uid=17)** arroja una longitud de respuesta notoriamente mayor de **1466 bytes**.
- **Conclusión Técnica:** Esta diferencia en el tamaño de la respuesta (+70-80 bytes) indica que el perfil perteneciente al uid=17 contiene elementos o campos adicionales en su estructura HTML (posiblemente un rol de administrador, comentarios ocultos, un token o la flag del laboratorio).



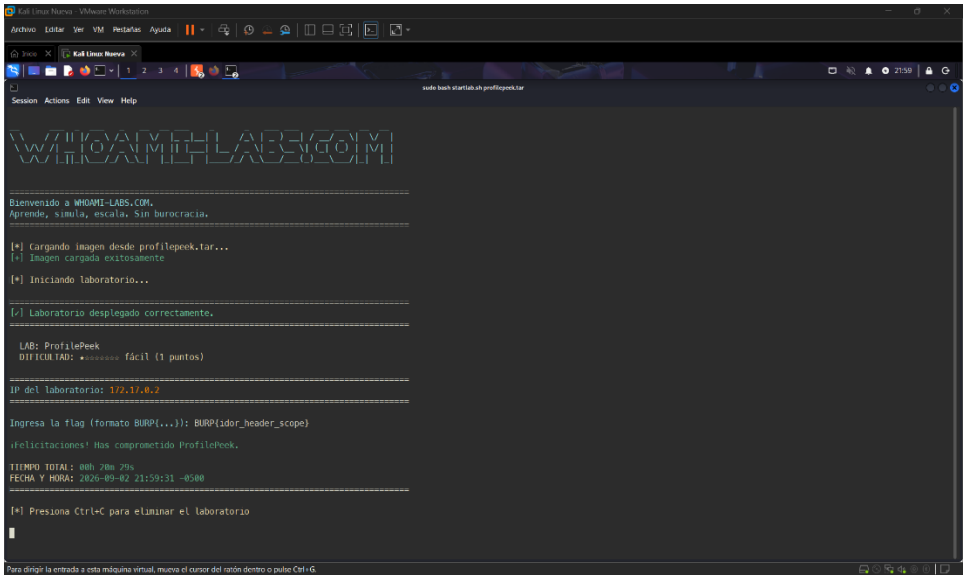
Inspección del Perfil uid=17 y Obtención de la Flag

- **Paso / Objetivo:** Analizar el contenido HTML devuelto en la respuesta HTTP correspondiente al payload uid=17 dentro de Burp Intruder para extraer la información restringida.
- **Herramientas: Burp Suite Intruder** (Pestaña Response / Vista Pretty).
- **Análisis de Resultados:** Al examinar el código HTML generado para el perfil nº 17, se identificó la cuenta del usuario privilegiado carol (*Carol CISO Admin*, correo: carol.ciso@corp.local). Dentro del cuerpo del perfil se renderizó una etiqueta especial con la clase flag que contenía el campo restringido.
- **Flag Obtenida:** BURP{idor_header_scope}



Validación y Finalización del Laboratorio

- **Paso / Objetivo:** Introducir la flag recuperada en la consola del laboratorio *WHOAMI-LABS* para validar el compromiso completo de la aplicación y finalizar el ejercicio.
- **Entorno:** Terminal de ejecución (startlab.sh).
- **Análisis de Resultados:** Se ingresó la flag BURP{idor_header_scope} en el prompt interactivo del script del laboratorio.



Conclusión Técnica

La vulnerabilidad en el laboratorio **ProfilePeek** radica en la falta de validación de autorización en el endpoint /profile. La aplicación confía únicamente en el parámetro uid enviado por el cliente mediante la URL para servir los datos del usuario, sin contrastar si el usuario que realiza la petición posee los privilegios necesarios o es el propietario legítimo de dicha información.

Recomendaciones de Seguridad (Remediación):

1. **Control de Acceso Basado en Roles (RBAC):** Implementar verificaciones de autorización en el lado del servidor antes de retornar cualquier perfil de usuario.
2. **Uso de Sesión / Contexto de Usuario:** En lugar de depender de parámetros editables en la URL (?uid=X), la aplicación debe obtener el identificador de usuario directamente desde el token de sesión autenticado y validado (session JWT).
3. **Identificadores Indescifrables (UUIDs):** Sustituir los identificadores enteros secuenciales (1, 2, 3...) por identificadores únicos universales (UUIDv4) para dificultar la enumeración masiva mediante fuzzing numérico.